Key Takeaways & Future Work

What we found

- **Verified traceability is achievable, and the closed vocabulary is what achieves it: 1.00 citation validity, sd 0.00, across 3,646 threats and three model families.**
- Grounding is necessary but not sufficient. Qwen3.5-2B fabricated 16 threat-tree nodes with the exhaustive menu in its prompt — verification is a real layer.
- A verifier can only check what its schema can express. Ours had two of LINDDUN Pro's three positions; frontier models silently coerced the third and still scored 1.00.
- Evaluate across model scales — not for generality, but to find your own bugs. Only a smaller model's different failure mode exposed the defect.

Where it goes next

- Human adjudication of false positives — every precision figure here is an uncorrected lower bound, because a threat absent from a curated catalog is counted as wrong.
- Re-adjudicate the gold with all three positions available: position can currently be checked for applicability, not for correctness.
- Semantic retrieval — both retrievers tested are lexical, so vocabulary mismatch between scenario prose and LINDDUN's formal wording is still untested.
- **Local deployment. A small model on one GPU cites as accurately as a frontier one, and a DFD names every field of personal data a system holds.**